

Keycloak

Ferramenta de gestão de identidade e acesso



O que vamos ver hoje

1

O problema que a **identidade** resolve

Por que cada sistema cuidar do próprio login não escala.

2

O que é o Keycloak

Definição, origem e o que ele entrega pronto.

3

Como ele funciona

O caminho de um login, em 4 passos simples.

4

Vantagens em microsserviços

Por que virou quase padrão nessas arquiteturas.

5

Adoção em monolitos

Análise sobre a utilidade da ferramenta num ambiente monolítico.

6

Síntese e quando (não) usar

Uma visão honesta, com prós e contras.



O PROBLEMA

Cada sistema, seu próprio login



Painel interno



App do cliente



ERP



Site institucional



Login próprio · senha própria · recuperação própria · MFA (ou não) próprio

“Se um funcionário sai hoje, o acesso dele foi cortado em todos os sistemas?”

DEFINIÇÃO

Um “porteiro” comum para todas as aplicações



IAM
Identity and Access Management

- Ferramenta de código aberto para gestão de identidade e acesso.
- Gratuita, licença Apache 2.0 — sem custo de licenciamento.
- Projeto da CNCF — a mesma fundação que mantém o Kubernetes.
- Usada por empresas e órgãos públicos ao redor do mundo.

O que ele resolve, pronto para usar



SSO

Um único login abre várias aplicações.



MFA

Segundo fator: app autenticador, chave física, biometria.



Login social

Entrar com Google, Microsoft, GitHub e outros.



Papéis e permissões

Define quem pode fazer o quê em cada sistema.



Recuperação de senha

Fluxo completo, com verificação de e-mail.



Painel administrativo

Console web e API própria para gerenciar tudo.

Como funciona, em 4 passos



A aplicação nunca vê a senha do usuário: só aprende a confiar em um “crachá” emitido por outro lugar.

Microserviços multiplicam o problema



Dezenas de serviços pequenos: cada um precisa saber “quem está falando comigo”.

Sem identidade centralizada, cada serviço reimplementaria login sozinho, e ainda precisaria confiar nos outros. É o mesmo problema do início, em escala muito maior.

Por que o Keycloak encaixa bem aqui



Token autocontido

Cada serviço valida sozinho — sem perguntar ao Keycloak a cada requisição.



Escalabilidade horizontal

Sem sessão compartilhada em banco: escalar de 2 para 200 serviços não muda nada.



Um único ponto de confiança

Revogar acesso ou mudar uma permissão tem efeito em todos os serviços de uma vez.



Interoperabilidade

Mesmo protocolo para qualquer linguagem — Java, Python, o que for.

E em um monolito? Também faz sentido



Monolito tradicional

- ✗ Autenticação misturada ao código de negócio.
- ✗ Senha e sessão vivem no mesmo banco da aplicação.
- ✗ MFA e SSO exigiriam desenvolvimento próprio, do zero.
- ✗ Crescer para múltiplos sistemas significa repetir tudo de novo.



Monolito + Keycloak

- ✓ Autenticação isolada em uma camada própria, fora do negócio.
- ✓ Login e permissões passam a ser responsabilidade do Keycloak.
- ✓ MFA e SSO chegam prontos, sem desenvolvimento adicional.
- ✓ Caminho aberto para crescer, sem reescrever a base depois.

Como essa adoção costuma acontecer



Mapear o login atual

Quantos usuários, quais regras, onde estão os dados hoje.



Migrar usuários e papéis

Levar essa base para dentro do Keycloak.



Trocar por um protocolo aberto

Sai a lógica caseira, entra o padrão (OIDC).



Preparar o terreno

Base pronta para, no futuro, virar microserviços.



Identidade não é “big bang”

A migração acontece em paralelo ao sistema em produção: usuários e telas de login trocam de lugar aos poucos, sem parar o negócio.

“A parte mais difícil de uma futura quebra em microserviços — identidade — já fica resolvida desde o início.”

Vale sempre a pena?



Faz sentido quando



Várias aplicações compartilham a mesma base de usuários.



Existe exigência de auditoria ou conformidade regulatória.



A equipe tem capacidade de operar mais uma peça de infraestrutura.



Pense duas vezes quando



O projeto é pequeno, um único sistema, sem previsão de crescer.



A equipe já está sobrecarregada para manter mais um serviço.



O prazo é curto demais para pagar a curva de aprendizado inicial.

Pra levar dessa aula



1 login, N aplicações

Um único ponto de entrada resolve o acesso a vários sistemas ao mesmo tempo.



Identidade separada do negócio

Não é só segurança — é uma decisão de arquitetura que facilita manutenção.



Mesmo protocolo, do monolito ao microsserviço

Adotar cedo não é desperdício: é investimento que se paga se o sistema crescer.

OBRIGADO

Perguntas?

Vale explorar o Keycloak com calma — dá pra subir localmente em minutos, só com Docker, e ver esse fluxo de login na prática.

keycloak.org

